

Grassroots Networking

NAT Detection and Hole-Punching Survey

Dan Bachar · dan.bachar@campus.technion.ac.il

1 Why this matters

Pain point. Every transport-layer decision in Grassroots Networking (GN) currently rests on an assumption about NAT that has never been measured. We do not know what fraction of our users sit behind carrier-grade NAT, whether hole-punching succeeds on the mobile carriers they actually use, whether IPv6 offers a path where IPv4 does not, or how long a NAT mapping survives on a phone with the screen off. Public NAT measurements exist, but they are dated and overwhelmingly desktop- and server-side; almost none are taken from handsets behind real carriers, which is exactly our deployment.

Goal. Design and validate a *grassroots* NAT-detection algorithm: one that determines a peer’s NAT behaviour and reachability using **social-graph peers as dial-back witnesses**, with no designated infrastructure. libp2p’s autoNAT v1/v2 nominally decentralize this, but in practice lean on a small set of well-known dial-back nodes. The question is what it costs to replace those with your friends, and whether the cost shrinks as the witness count grows.

Decisions this unblocks. Whether rendezvous anchors are needed by the median user or only as a fallback; whether to keep investing in UDP at all versus pushing BLE harder; whether we ever ship a relay; how hard to push IPv6 over IPv4; and what the transport should actually *do* at dial time instead of the fixed 2-second punch and 10-second timeout it uses today.

Why it is a grassroots question. The founding claim of the system is “no infrastructure”. Every anchor and every relay erodes it a little. Knowing empirically how many users we can reach with pure peer-to-peer transport tells us how much infrastructure is genuinely load-bearing and how much is over-engineering — and gives the lab a defensible answer when a reviewer challenges the premise.

2 Motivation

GN spans local BLE hops and remote UDP paths. The remote half assumes successful NAT traversal across heterogeneous home, mobile, and enterprise networks, and the decision space for it — direct UDP with hole punching, anchor-mediated rendezvous, or a full relay — depends critically on real-world NAT prevalence, CGNAT deployment, and IPv6 reachability.

Mobile is the hard case and the under-measured one. A handset behind a carrier’s CGNAT cannot observe its own outer address, cannot accept unsolicited inbound traffic, and may be assigned a different external port for every destination it contacts. Desktop tooling cannot see any of this: it is not behind the carrier. Measuring it requires code running on real handsets, on real SIMs, on the networks those SIMs actually traverse.

3 How Grassroots Networking connects peers today

This section is the starting point for the work: it describes the shipped IP path in the order it executes, so that the gaps in Section 4 are concrete rather than abstract. References are to files in the `grassroots_networking` repository.

3.1 Sockets and self-address

The transport binds two wildcard UDP sockets, one per address family, **both on port 0** — the OS assigns an ephemeral port, and every rebind produces a new one (`lib/src/transport/udp_transport_service.dart:1009`). There is no fixed or configurable port, so there is no port-forwarding story. A `UDXMultiplexer` then wraps each socket and **owns all reads** from it (`udp_transport_service.dart:264`).

The device learns its own address in two ways:

1. **HTTPS reflection.** A GET to `https://ipv4.seeip.org` or `https://ipv6.seeip.org`, cached five minutes per family (`public_address_discovery.dart:40`).
2. **ADDR_REFLECT** (signaling type `0x07`). A peer that is itself well-connected observes our source `ip:port` on an incoming session and reflects it back (`signaling_service.dart:760`).

There is **no STUN client** — no Binding Request, no magic cookie, no XOR-MAPPED-ADDRESS anywhere in the repository.

The single most consequential line in the subsystem: the address the device advertises is the externally-discovered **public IP paired with its locally-bound port** (`public_address_discovery.dart:97-104`). That reveals the public IP but *never the NAT-mapped port*. The only true mapped port arrives via `ADDR_REFLECT`, which requires a session that already works — so it cannot help in the case where nothing has connected yet, which is precisely the case this project addresses.

Self-classification is a single boolean: `isWellConnected == hasPublicUdpAddress`, a routability test on that advertised string (`transports_state.dart:94`, `peers_state.dart:248`). The routability test itself is correct — `isGloballyRoutableIPv4` excludes `100.64/10` and the rest of the reserved space (`address_utils.dart:138`) — but a phone behind carrier NAT never *sees* its `100.64` inner address, so that exclusion never fires.

3.2 Advertising and candidates

`ANNOUNCE` carries `pubkey(32) | version(2) | nickname | candidates | Ed25519 signature(64)`, self-signed, and throws on a bad signature (`protocol_handler.dart:173`). Candidates are plain `ip:port` strings, with IPv6 bracketed: the discovered public candidates plus the link-local IPv6, filtered to families that have a bound socket. `ANNOUNCE` repeats every **10 s** (`grassroots_network.dart:78`); the same tick drives liveness (a peer is stale at 20 s), reconnection, and the queued-message drain. There is **no dedicated NAT keepalive** — that 10 s tick is the de facto one, and it fires only over already-established connections.

3.3 Choosing where to dial

`UdpConnectionService.selectBestPair` scans every local $\times$ remote pair and returns exactly one, ranked link-local-same-subnet > IPv6 > IPv4 (`connection_service.dart:48`). Only the remote half of the pair is dialed. **Nothing probes candidates in parallel, nothing validates a candidate, and nothing falls back to second-best after a failed dial.** The lexicographically smaller Ed25519 public key is the deterministic initiator.

3.4 Punching

The punch packet is **36 bytes**: the magic BCPU followed by the sender’s 32-byte public key — no nonce, timestamp, sequence number, or signature (`hole_punch_service.dart:18`). The punch itself is fire-and-forget: **2 s at 200 ms, roughly 10 datagrams**, to one address and one port, with no port prediction and no sweep (`hole_punch_service.dart:117`).

A closed-loop mode exists (`punchUntilResponse`), but it has **no production caller and cannot work as currently wired**, because it reads the raw socket while the multiplexer owns reads. Inbound punch packets are dropped before any accounting (`udp_transport_service.dart:848`).

Punching is therefore **open-loop**: the system cannot distinguish “the NAT refused the mapping” from “packets were lost” from “the port was wrong” from “the handshake was merely slow”.

3.5 Dialing and failure

One UDX attempt, with `connectHandshakeTimeout = 10 s`, and **no retry loop and no second candidate inside the transport** (`udp_transport_service.dart:58`). Failures are classified into `{networkUnreachable, handshakeTimeout, other}`; retries live outside the transport at 15 s, 60 s and 5-minute backoffs. Note that UDX’s `handshakeComplete` fires **on the first valid packet from the remote** — it is a round-trip liveness signal, not a cryptographic handshake. Authentication is `Noise_XX` over the stream, and the router drops every clear non-ANNOUNCE packet.

3.6 Mediation

Eleven signaling types occupy `0x05–0x0f` (`0x10` and above are free, so new witness messages are purely additive). All of them ride inside Noise; clear signaling is refused on both ends. Trust is a static three-way OR: an accepted friend, a configured rendezvous public key, or a friend-advertised rendezvous server (`signaling_service.dart:849`). There is no reputation, no cross-checking, and no quorum.

A **friend mediator** coordinates a punch only when the target is a friend, is reachable *on the mediator right now*, and both addresses are in the same family. A **rendezvous anchor** runs the two-sided RECONNECT/AVAILABLE matcher with a five-minute pending expiry. The deployed anchor opens exactly one data-plane firewall rule — `udp:9516` from `::/0`, **IPv6 only**.

4 What the system does not know

Ranked by how much each blocks a real decision.

1. **No NAT classification at all — and the boolean standing in for it is systematically wrong for exactly the devices that matter.** A phone behind carrier NAT that can reach `seeip.org` advertises a globally routable IP, and classifies itself (and is classified by every peer) as **well-connected**. Three live behaviours run off that false positive: the pre-connect punch is *suppressed* when a peer looks public (`grassroots_network.dart:3369-3373`), so it is skipped for precisely the peers that need it; the phone begins acting as an address reflector and rendezvous facilitator for its friends; and the user interface reports that the device is well-connected. Nothing anywhere distinguishes “*has a public IP*” from “*is reachable at that ip:port*”.
2. **No mapped-port discovery on the primary path.** The port we tell every peer to dial is a guess.
3. **Multi-reflector disagreement is discarded.** Several anchors and several well-connected friends can each reflect the same socket — which is exactly RFC 5780 mapping-behaviour raw material. The handler overwrites the stored address wholesale and records nothing, so two disagreeing reflections are indistinguishable from roaming.
4. **No dial-back protocol and no notion of a witness.** “Am I reachable from outside?” is asserted from a string prefix and never tested. The inbound-connection observation point exists but is write-only: nothing reads it for a decision.
5. **Zero timing instrumentation.** There is no `Stopwatch` anywhere in `lib/`. The only record of a punch is a four-value enum with no timestamps, and the reducer discards the failure reason. No latency or robustness comparison is computable from what the application records today.
6. **No two-endpoint probe infrastructure.** RFC 5780 requires two IP addresses and two ports per family; the anchor binds one port per family and opens one IPv6 rule.
7. **No persistence or export.** Address tables are in-memory with a five-minute TTL, so any dataset deliverable currently has neither a producer nor a sink.

Three further items are production defects rather than research gaps, and they bear on this work because the probe rides the same paths: the punch target taken from `PUNCH_INITIATE` is never checked against `isGloballyRoutableAddress`, so any trusted sender can steer roughly ten datagrams at an arbitrary `ip:port` — including private or multicast addresses on the victim’s own LAN; the mediator’s pending-coordination map has no TTL or sweep; and the stream framer trusts an attacker-supplied 32-bit length with no bound (`udp_transport_service.dart:1103`).

5 A worked example

Maya — an Android handset, cellular only, behind carrier CGNAT, IPv4-only path. **Noam** — home Wi-Fi behind a consumer router (endpoint-independent mapping, address-and-port-dependent filtering), with IPv4 and a working IPv6 prefix. They are accepted friends, previously paired over BLE, now geographically apart.

1. Maya’s `seeip.org` lookup returns the carrier’s *outer* public IPv4 — globally routable by our test, because the inner 100.64 address is never visible to the handset. The advertised candidate is that IP paired with Maya’s **local** port.
2. Both devices compute `isWellConnected = true`. Maya’s UI says “well-connected”. This is wrong twice over: the advertised port is not the mapped port, and the carrier NAT will not accept

unsolicited inbound traffic at all.

3. Maya tries to add the deployed anchor. Its data-plane rule is IPv6-only, so the attempt times out after 8 s and the server is refused. Maya now has **no path to ever learn her mapped port**.
4. Maya sends a message. Candidate selection prefers Noam’s IPv6 address because Maya’s IPv6 *socket* is bound — even though she has no IPv6 transit. One dial, 10 s, timeout, and **no fallback to the IPv4 pair**.
5. The pre-connect punch is suppressed on both sides, because each sees the other as public. Had it fired, it would have targeted the local ports anyway.
6. Friend-mediated rendezvous requires a mutual friend who has Noam reachable *right now* and a same-family address for both. Even when that succeeds, if Maya’s carrier assigns a different mapped port per destination, the mapping the mediator observed is not the one Noam’s packets will hit, and every datagram lands on a closed pinhole.
7. Nothing is recorded: no attempt identifier, no timestamps, no per-candidate outcome, and no distinction between “wrong port”, “filtered”, “no route”, and “peer offline”.

And when it works, it works blindly. Put both peers on port-preserving, endpoint-independent NATs and the advertised local port happens to equal the mapped port, the first dial succeeds, and the system learns nothing. The identical code fails on the next carrier with no diagnostic difference in the logs.

6 Research questions

RQ1 — Can social-graph witnesses replace designated dial-back servers? Specify and validate a witness-based algorithm that recovers a peer’s mapping and filtering behaviour, and quantify its agreement with an RFC 5780 oracle.

RQ2 — What does decentralization cost? How do the false-negative rate and time-to-verdict move with the witness count k and the byzantine fraction f , colluding and independent? Does the gap to a designated-server baseline close as k grows, or is there an inherent floor? And — the constraint that will probably dominate — what is $P(\geq k \text{ witnesses online and dialable})$, swept over plausible online-fraction and friend-count distributions?

RQ3 — What is the NAT reality for a user population like ours? Two layers.

Measured: the tuple — mapping behaviour $\times$ filtering behaviour $\times$ port preservation $\times$ mapping lifetime, plus CGNAT status and IPv6 path type — recorded **per stratum** on our own handsets across every carrier and access network in the testbed, and reported as a per-stratum table. A distribution appears only after weighting, in the layer below.

Estimated: population prevalence, obtained by treating the testbed as a **stratified census with a small number of measurements per stratum**, weighted post hoc by published subscriber counts and per-AS end-user estimates. Note the word: this is a *census of strata*, not a stratified *sample* — there is no probabilistic sampling within a stratum, so no confidence interval is computable, and every interval reported is an assumption-sensitivity range.

Denominator, stated once: the estimate is over **consumer-APN mobile lines and residential broadband lines in the countries we cover, as of the measurement date** — not over devices,

not over humans, and not over GN users. Published subscriber counts include M2M and data-only lines; net these out where the source permits and flag the residual where it does not. Mapping this denominator onto GN’s actual users assumes GN users distribute across carriers and access networks like the general population, which is an assumption, not a finding.

RQ4 — What should the transport do at dial time? An empirical decision rule — direct, anchor-mediated, or give up — over the inputs the transport actually holds when it must decide.

6.1 Defining the measurand

Not “NAT type”. The measurand is a tuple: mapping behaviour {endpoint-independent, address-dependent, address-and-port-dependent} $\times$ filtering behaviour {EIF, ADF, APDF} $\times$ port preservation $\times$ mapping lifetime, plus the orthogonal facts (CGNAT-suspected, IPv6 available, IPv6 routable). Any single-label “NAT type” is a derived convenience column, and must be marked as one.

Measure and report the tuple **per address family and per translation path** — NAT44, NAT64/464XLAT, or native IPv6. This matters more than it appears: on a 464XLAT path the thing being characterized is the carrier’s PLAT, which the RFC 4787 NAT44 vocabulary describes only partially, and on a native IPv6 path there is typically no mapping at all — only stateful filtering — so mapping behaviour and port preservation are **N/A**, which is not the same as absent. Path type splits strata; it is not an orthogonal fact.

6.2 What autoNAT does and does not give you

autoNAT is not a NAT classifier. Version 1 answers “am I publicly reachable”; version 2 answers “is *this address* dialable”, per address, with a nonce’d dial-back. Neither emits a mapping- or filtering-behaviour label. The head-to-head comparison against autoNAT is therefore **reachability-only**, and the ground truth for classification is an RFC 5780 oracle that the project stands up itself.

7 Approach

7.1 Where the code lives

Build inside `grassroots_networking`, in `lib/src/transport/`. That is the system the decision rule must serve, and `ADDR_REFLECT` is already a working reflection primitive. The IP transport is `grassroots_dart_udx` (a fork of `dart_udx`) with its own signaling and hole-punch path, so the probe is written against that transport rather than against a general-purpose p2p stack.

7.2 Probe from the transport’s own socket

One wildcard socket per family, serving every peer, is exactly the precondition the RFC 5780 mapping tests require, in RFC 4787 terms; a second socket has a different NAT mapping and measures a different thing. The fork exposes `UDXMultiplexer.onRawPacket` for precisely this purpose. Three traps are worth stating explicitly, because each costs a day:

- `_handleRawPacket` drops anything **under 50 bytes** and drops 36-byte BCPU packets, so a probe packet must be at least 50 bytes and carry its own magic.
- **Do not reuse `sendRawTo`** — it registers the target in a map that `stop()` does not clear, so the 10s ANNOUNCE broadcast would begin fanning out to measurement targets.
- `punchUntilResponse` is dead today because it reads the raw socket while the multiplexer owns reads. That is the same wall any second reader will hit.

7.3 The two RFC 5780 dimensions are not equally reachable from social witnesses

Mapping behaviour is the easy half. It needs the mapped `ip:port` reflected from at least two witnesses at distinct IP addresses, plus one at a distinct port. `ADDR_REFLECT` already does the reflection; what remains is to reflect from a *second distinct address* and to retain every (`reflector`, `observed tuple`, `timestamp`) rather than last-writer-wins.

Filtering behaviour is the actual contribution. It requires an inbound packet from an endpoint the probe has never sent to — which no single witness can produce for itself. Specify it as a relayed dial-back: the probe sends W1 a nonce, its mapped tuple, and the requested source class; W1 instructs W2 (a witness the probe has not contacted) to dial back; W2 dials the probe carrying the nonce. Three arms — dial-back from (same IP, contacted port), (same IP, new port), and (new IP) — yield EIF, ADF, and APDF respectively.

7.4 Guard against contamination

This is the central validity threat, and it is invisible unless you look for it. Social witnesses are exactly the peers the device already sends to: ANNOUNCE every 10s, plus roughly ten punch datagrams per attempt. A dial-back from an endpoint you have already contacted traverses a hole *you* opened, so it measures your own mapping and will systematically report NATs as far more permissive than they are.

Keep a per-test send history of every (`dst ip`, `dst port`) emitted on the measured socket, treat “witness source was previously contacted” as a **logged discard condition**, and require every filtering-arm dial-back to come from an endpoint never sent to. Then run the with/without-prior-contact comparison on the bench and publish the figure: the label flip is itself a result about why naive witness-based reachability tests over-report.

7.5 Aggregation rule

A nonce’d dial-back is unforgeable, so **one honest witness suffices to prove reachability**, whereas a claimed *failure* is cheap to fabricate or withhold. The sound rule is therefore asymmetric: *any verified success* $\rightarrow$ *reachable*; *declare unreachable only after k independent witnesses fail*. A symmetric majority vote is the wrong shape.

Byzantine witnesses are cheap to study on a testbed and should be studied there: run k witness processes under our control, instruct f of them to lie — claim dials they never performed, withhold successes, collude on a story — and sweep. That yields a cleaner adversarial result than any live deployment, because the ground truth of who lied is ours by construction. The one thing the testbed

cannot supply is the real online-friend-count distribution behind $P(\geq k \text{ available})$, so derive that curve parametrically and state it as a parametric result rather than a measured one.

7.6 Threat model and three defences

Write the threat model — adversary capabilities (byzantine fraction, colluding versus independent, on-path versus off-path, spoofing-capable or not) and named security goals — and implement three defences before the probe runs anywhere outside the bench:

1. A client-chosen nonce echoed in the dial-back, so a witness cannot claim a dial it never performed.
2. An off-path dial must target the requester’s *observed* source, or carry an autoNAT-v2-style proof-of-cost — and report what that costs in bytes and latency.
3. Per-requester rate limiting, and a hard refusal to dial or punch any non-globally-routable target (`isGloballyRoutableAddress` already exists; it is simply not applied on the punch path).

Additionally, require at least two independent witnesses to agree before mutating the stored public address. Without these, a witness protocol layered on today’s code is *strictly weaker* than autoNAT v1, whose entire anti-amplification stance was to refuse dialing any address other than the requester’s observed source.

Keep measurement traffic inside the testbed mechanically: enforce a hard target allowlist at the send path, so probes and punches may only target testbed infrastructure and our own devices, and a witness-supplied address can never bypass it. Never enable measurement on the live build.

7.7 Ground truth: a testbed we control, in two tiers

Tier 1 — synthetic bench, labelled by construction. Spanning the mapping axis takes more than netfilter flags, and getting this wrong would quietly break the bench: default `MASQUERADE` reuses a mapping for the same source tuple and reads externally as **endpoint-independent**; `-random-fully` picks a fresh port per flow and reads as **address-and-port-dependent**; and `-persistent` is a SNAT source-*address* pool control that is not on the mapping axis at all. There is no netfilter knob for the middle class, so the **address-dependent** case must be constructed deliberately — per-destination SNAT via nftables maps keyed on destination address, or a userspace NAT. Add filtering variants spanning EIF, ADF and APDF, two to three commercial CPE routers, and a double-NAT/CGNAT emulation. Because every label here is known by construction, “accuracy”, precision/recall and confusion matrices are legitimate, and this is where the algorithm’s correctness claim is established.

Tier 2 — our own devices on real access networks. A handful of handsets we own, carrying prepaid SIMs across the local carriers, moved across the access networks we can physically reach: home, office, university, and public or commercial Wi-Fi, plus at least one enterprise-style network where possible. No labels exist here, so report **“agreement with the oracle”**, never “accuracy”, and treat disagreements as a category with hypotheses (mapping churn mid-test, oracle rate-limited, multi-path). This tier is what shows the algorithm survives contact with NAT behaviour nobody constructed.

7.8 Population prevalence by stratified estimation

A convenience sample of our own handsets cannot be averaged into a prevalence figure directly — but it does not have to be. NAT behaviour is mostly a property of *the network path*, not of the individual subscriber: every customer of one mobile carrier, on the same APN and PDN type, traverses the same small set of gateway configurations. So characterize each **stratum** in the testbed, then weight strata by published population data — accepting up front that with few measurements per stratum the within-stratum variance is not estimable, only bounded by assumption.

The residual subscriber-level determinants are named rather than wished away. The **handset stack** decides the requested PDN type and whether a CLAT is present — Android ships 464XLAT and iOS does not behave identically — so two subscribers on one carrier and APN with different phones can traverse different translators and yield different measurands. Every cellular stratum is therefore measured on **at least two handset stacks, one Android and one iOS**.

- **Cellular strata** — one per (carrier, APN, PDN type), *not* one per carrier. This is the *tractable* half, not the certain half: few strata, each cheap to enumerate, each carrying large weight — which is exactly why an undetected error inside one is expensive. Near-homogeneity within a carrier is an *assumption*, and the named ways it fails are APN (prepaid versus postpaid versus corporate versus M2M, and a consumer prepaid SIM generally cannot reach the others), MVNO arrangement (a full MVNO runs its own core and NAT and is a separate stratum riding the same brand’s market-share row; a light MVNO is not), regional PGW/CGNAT pool, and pool-exhaustion behaviour under load. Weights come from published subscriber counts and market-share reports, cross-checked against per-AS end-user estimates.
- **Residential strata** — by **ISP** $\times$ **whether that ISP CGNATs the subscriber**, with CPE vendor and firmware family as a second-order split inside the non-CGNAT cells only. That ordering is the whole point: if carrier-grade NAT sits *above* the CPE, the CPE’s mapping and port-preservation behaviour are invisible from outside and the vendor axis explains nothing. It also fixes the weights, since ISP subscriber share is published while CPE share by firmware family is not. This is the *weak* half: inside the second-order split, many models, drifting firmware and subscriber-configurable settings mean within-cell homogeneity is a real assumption rather than a near-certainty. Weight availability is itself a risk — vendor-share figures are shipment-based, rarely per-ISP, never per firmware family — so decide the fallback early: if per-ISP CPE weights cannot be obtained, report residential as an **interval across observed cells**, weighting only the **ISP $\times$ CGNAT** axis, with no point estimate and no invented weights.
- **Managed and public Wi-Fi strata** — university, office, commercial hotspot. Weights here are the shakiest; treat these as a characterized set with a coarse, explicitly uncertain weight.
- **Residual stratum** — everything the above does not cover: tethered and hotspot clients (whose NAT stacks above the carrier’s), VPN and private-relay users (who replace the measured path entirely, and are over-represented in exactly the privacy-conscious population GN attracts), fixed-wireless and satellite home broadband (called residential, but the mechanism is a cellular-style gateway), and enterprise networks. We do not measure this stratum; we carry it with its best-available weight and it enters the bound at both extremes. **This is what makes the weight table sum to the denominator** — without it the strata do not partition the population.

Report prevalence as an estimate with its weight table attached, and run a **sensitivity analysis in four arms**: (i) recompute under each independent published weighting and vintage; (ii) a genuine worst/best-case bound assigning all unmeasured and heterogeneity-uncertain mass to the least, then

the most, favourable point in the measurand domain — *this is the only arm that bounds the conclusion*; (iii) a “behaves like the worst observed stratum” arm, labelled a realistic-pessimistic variant and never a bound; (iv) a within-stratum-heterogeneity arm that perturbs each measured stratum’s label across whatever its homogeneity check observed, and across the full domain where no second measurement exists. Report which envelope dominates — if heterogeneity dominates the weights, say so, because then the honest headline is a range rather than a number.

Report the tractable and weak halves separately: a defensible cellular/CGNAT estimate plus a bounded residential one beats a blended number nobody can audit. Cross-check against published NAT and DCUtR measurement studies **only after reconciling denominators** — those estimate over libp2p nodes and traversal attempts, skewed toward always-on desktop and datacenter hosts, which is close to the complement of our handset population, so raw agreement or disagreement is evidence of nothing. Compare where the denominators overlap, and say plainly where they cannot be reconciled.

On weight sources, be concrete about limits. Per-AS **end-user** estimates (APNIC’s, for example) estimate eyeball users per AS from an ad-delivered sample, and cannot be split into cellular and fixed for a carrier announcing both under one ASN. Use published subscriber counts as the primary weight and per-AS user estimates as the cross-check — never AS *size* in announced address space, which is close to uncorrelated with user count once CGNAT is involved and would systematically down-weight exactly the strata this study is about.

Coverage is a purchasing decision, and a cheap one: each additional prepaid SIM opens another cellular cell, and a travelling colleague with a spare handset is another country.

7.9 Baselines

Integrate the reference implementation as a sidecar (go-libp2p p2p/protocol/autonatv2), never a reimplementation — otherwise the “baseline” is the student’s own partial protocol and any gap is unattributable. Declare the head-to-head **Android-only** and state it as a limitation. Budget the uplink: autoNAT v2’s amplification defence has the client push a large `DialData` payload before any off-path dial, which is both a metered-data consideration and a latency confound, so report **bytes on the wire per verdict** alongside latency.

7.10 Instrumentation is a deliverable, not a side effect

Record per attempt: attempt identifier, peer, candidate, family, path taken (direct, pre-connect punch, mediated, BLE-assisted), phase timestamps, outcome, and failure kind — with a durable sink. Stamp the attempt identifier on every measurement-relevant control message, so both endpoints’ records join into one observation. Add a measurement mode that quiesces the 10s announce timer during a mapping-lifetime probe, and stamp every sample with interface type, radio technology, screen state, foreground/background state, and battery-saver state.

7.11 What to reuse rather than rebuild

`hole_punch_service.dart` (both punch modes; the closed-loop one is already unit-tested); `udp_transport_service.dart` (`rawSocketsByType`, raw send/receive alongside UDX on the same socket, `UdpConnectFailureKind`, `getRemoteAddress`, `probeAndRebindIfDead`); `address_utils.dart` (a ready-

made address-class labeller — CGNAT, ULA, Teredo and 6to4 already excluded); `connection_service.dart` (the candidate scorer — add a probe loop on top, do not rewrite selection); the signaling control plane (0x10+ free, so new witness types are purely additive); `noise_session_manager.dart` (an authenticated, replay-protected channel — no new crypto work); `peer_link.dart` together with the anchor’s redemption handler (a complete signed-capability template with expiry, single-use atomic flip and constant-time compare — the right shape for a witness attestation); all of `bootstrap_anchor/` (the only Flutter-free deployable component, with Dockerfile, GCE deploy script, dual-family bind, observed-source extraction and the two-sided matcher); and `putPeerAddress` (the sanctioned way to feed measured addresses back into the transport without touching the social graph).

8 Deliverables (incl. evaluation data)

- **The grassroots NAT-detection algorithm** — specification with a stated threat model, reference implementation in `grassroots_networking`, and validation against an RFC 5780 oracle on a labelled bench.
- **Reachability head-to-head** against libp2p autoNAT v1 and v2, on the same device, network and time window (Android).
- **Testbed dataset** — every bench configuration with its construction label, and every characterized stratum with its measured tuple. Released whole: these are our own devices on our own SIMs, so there is nothing to withhold. Two practical checks first — the acceptable-use terms of each prepaid and residential plan, since consumer terms sometimes bar network probing; and whether to publish our own home and carrier-facing addresses verbatim or under a stable pseudonym, which costs nothing and preserves every join.
- **Population prevalence estimates** — per-stratum measurements weighted by published subscriber counts and per-AS end-user estimates, carrying the weight table, the stated denominator, the measurement date, the assumptions, and the four-arm sensitivity analysis, with cellular reported separately from residential. Every interval is an **assumption-sensitivity range, not a confidence interval**: the design contains no random sampling, so no standard error exists and no “±” may be printed as if one did.
- **Empirical decision rule** for the GN transport, validated by replay on a held-out split.
- **Per-attempt instrumentation subsystem** — useful to the product regardless of the paper.
- **Technical report**, targeting ANRW or PAM; pick the deadline in month 1.

Scope, stated up front. The primary claim is the witness-based detection algorithm, validated on labelled ground truth and exercised against real access networks. Supporting claims: the stratified prevalence estimate, the reachability head-to-head, and the transport decision rule. If time permits: broadening testbed coverage — more carriers, more countries via travelling handsets, which directly buys estimate quality — and the IPv6 story, which falls out of the main data and is not a separate contribution. A longitudinal DCUtR/IPFS campaign already covers millions of traversal attempts across tens of thousands of networks; our defensible axes are **cellular carriers and CGNAT on real handsets** (that literature is overwhelmingly desktop and server) and **witness decentralization**. Write related work in month 1, not month 6, and state which of those findings you expect to reproduce and which to contradict.

9 Milestones

Window	Work	Exit criterion
Month 1	Scope lock; measurand in RFC 4787/5780 terms; threat model; aggregation rule; related work; stratum design and testbed inventory.	A 6–8 page design document containing the test-to-witness-topology table; the threat model with named security goals; the asymmetric aggregation rule; the stratum definition with its weight sources named and their coverage of the target population computed; and a testbed inventory naming every handset, SIM, CPE router and access network needed, marking what is in hand and what must be bought.
Month 2	RFC 5780 oracle on two public IPs $\times$ two ports ; labelled lab bench, with the address-dependent mapping case constructed deliberately since no netfilter flag produces it.	One command runs the oracle against at least 8 lab configurations and emits a confusion matrix; all three mapping classes are present, the address-dependent one demonstrably so; agreement with construction labels $\geq 95\%$, every disagreement explained; reproduces from a clean checkout.
Month 3	Witness detection v1: nonce'd dial-back, relayed filtering test, contamination guard, the three anti-amplification defences, multi-witness aggregation.	With three honest witnesses, reproduces the oracle's mapping and filtering labels on ≥ 8 known configurations at $\geq 90\%$ agreement. Tests prove three adversarial properties: a witness cannot flip a verdict by claiming a dial it never performed; a witness cannot induce a dial or punch toward a third-party address; a dial-back from a previously contacted endpoint is discarded. Plus one figure showing the label flip between contaminated and clean runs.
Month 4	autoNAT sidecar; back-to-back harness (GN detection, autoNAT v1, autoNAT v2, oracle) on one device, network and window; sweep k against byzantine fraction $f \in \{0, 0.1, 0.3, 0.5\}$ with lying witnesses we operate.	One CSV row per (device, network, epoch) carrying all four verdicts plus latency, bytes and battery; plots of false-negative and false-positive rate versus k for each f ; time-to-verdict versus k ; and a parametric $P(\geq k \text{ witnesses available})$ curve over online fraction and friend count.
Month 5	Testbed campaign across every stratum: handset $\times$ SIM $\times$ access network, repeated over screen on/off and foreground/background, with roaming and handover triggered deliberately; mapping-lifetime probes per network.	Every stratum characterized with its full tuple, each measurement repeated on ≥ 2 days spanning one peak and one off-peak window; each cellular stratum measured on ≥ 2 independent subscriber configurations (≥ 2 SIMs differing in prepaid/postpaid or MVNO/host, and ≥ 2 handset stacks, at least one Android and one iOS), with pairwise agreement reported as the within-stratum homogeneity check — a disagreement splits the stratum rather than being averaged away; every unreachable stratum listed with its reason and population weight.

Window	Work	Exit criterion
Month 6	Weight strata into population prevalence with the four-arm sensitivity analysis; fit the decision rule; measure the address-exposure cost of decentralization; write and submit; package the artifact.	Prevalence estimates carrying the weight table, denominator and date, cellular and residential separate, all four sensitivity arms reported and the dominant envelope named, no interval presented as a confidence interval, compared against published studies only where denominators reconcile. Decision rule as a predicate table over dial-time inputs, validated on a held-out split, with precision/recall for “direct will succeed” and the time saved versus today’s fixed 2s punch and 10s handshake timeout. A figure showing how many distinct peers learn a device’s address per day, witness-based versus designated-server. A submission-ready paper, and one script that regenerates every figure from the released data.

Start the IP allocation and firewall work in week 1 — that is latency which cannot be absorbed in month 2.

10 Recommended skills

- Basic mobile application development (or Claude).
- Basic networking; experience with a peer-to-peer stack is a significant plus.
- Statistics.
- Matplotlib, R, or any plotting library.

Dart and Flutter are learnable during month 1; the networking intuition is the part that is hard to shortcut.

11 Decisions to lock before starting

1. **Stack.** Confirm that the probe lives in `grassroots_networking`, on the transport’s own socket.
2. **Baseline shape.** A go-libp2p sidecar (high fidelity, Android-only) or a same-socket reimplementa-tion (comparable probe, but the baseline becomes the student’s own protocol)? This single decision most changes the shape of the tool.
3. **Primary claim.** The *algorithm* or the *measurement*? Both cannot be first-class in six months.
4. **Oracle infrastructure.** Who provisions the dual-homed RFC 5780 server, and can the alternate addresses come from the static IPv6 /96 already reserved on the existing VM? This gates month 2, so check it in week 1.
5. **Anchor IPv4.** The anchor’s data-plane rule is IPv6-only, which excludes exactly the IPv4-only CGNAT population the study targets. Open an IPv4 rule, or accept and document the exclusion?
6. **Testbed budget and coverage floor.** How many handsets and prepaid SIMs, and which carriers? Each *carrier* is a candidate stratum, but each SIM buys only one (carrier, APN, plan)

cell of it, and at least two cells plus two handset stacks per carrier are needed before homogeneity can be checked rather than assumed — so budget roughly double the naive count. Procurement is slow; decide early.

7. **Security fixes.** The unvalidated punch target, the missing rate limits, the uncorroborated `ADDR_REFLECT` and the unbounded framer length are production defects independent of this project. Student work or team work?
8. **Instrumentation ownership.** Does the per-attempt record land in `main` as a permanent subsystem, or in a measurement branch that is discarded afterwards?

Glossary

464XLAT / CLAT

A mechanism that lets an IPv4-only application work over an IPv6-only mobile network: the handset (the CLAT) translates IPv4 to IPv6, and the carrier (the PLAT) translates back. Android ships it; iOS does not behave identically — which is why the handset, not just the network, can change what a NAT measurement sees.

Anchor server (in GN)

A lightweight server that helps two peers find each other. Each user can run one for their friends; its identity is derived deterministically from a seed.

APN (Access Point Name)

The named gateway configuration a mobile device uses to reach the packet core. Prepaid, post-paid, corporate and M2M plans often use different APNs — and therefore potentially different NAT behaviour on the same carrier.

autoNAT (libp2p)

A libp2p service in which a node asks other nodes to dial it back to determine whether it is publicly reachable. Version 1 answers reachability overall; version 2 answers it per address with a nonce'd dial-back. In practice both rely on a small set of well-known dial-back servers, which is what this project sets out to replace. Neither version classifies NAT behaviour.

BLE (Bluetooth Low Energy)

The low-power Bluetooth variant used for short-range device-to-device communication, and GN's local transport.

CGNAT (Carrier-Grade NAT)

NAT applied by an ISP — usually a mobile carrier — to share one public IPv4 address across many customers. Common on cellular networks, and especially hostile to peer-to-peer connections, because even the “public” address is shared with strangers.

Dial-back

When peer A asks peer B to try to connect back to A. If B succeeds, A learns it is publicly reachable; if B fails, A is probably behind a NAT.

DCUtR

libp2p's Direct Connection Upgrade through Relay: a hole-punching coordination protocol whose large-scale measurements are the closest published comparison to this work, though taken over a very different population.

Filtering behaviour (EIF / ADF / APDF)

What a NAT accepts *inbound* on an existing mapping: endpoint-independent (anyone may use it), address-dependent (only hosts you have sent to), or address-and-port-dependent (only exact endpoints you have sent to). Measuring it requires a packet from somewhere you have never sent to.

Hole punching

Two peers behind NATs simultaneously send packets toward each other; each NAT sees the outgoing packet and temporarily permits the matching reply, even though neither side formally initiated. Works for many NAT behaviours, and generally fails against address-and-port-dependent mapping.

ICE (RFC 8445)

The standard procedure by which two peers discover the best working path between them: direct, then hole-punched, then relayed. The protocol underneath WebRTC.

IPv6

The 128-bit Internet addressing scheme. In principle every device gets a unique public address and NAT becomes unnecessary; in practice adoption is patchy, and mobile IPv6 often arrives together with a translator rather than a clean end-to-end path.

libp2p

An open-source modular peer-to-peer networking stack used by IPFS, Ethereum and others, providing peer discovery, secure transports, NAT traversal and content routing.

Mapping behaviour

How a NAT assigns the external port for outgoing traffic: endpoint-independent (the same external port for every destination), address-dependent, or address-and-port-dependent (a fresh port per destination, which defeats hole punching because no one can predict where to send).

Mapping lifetime

How long a NAT keeps an idle mapping before discarding it — the quantity that determines how often a keepalive must be sent to hold a path open.

MVNO

A mobile operator that resells service on another operator’s radio network. A “full” MVNO runs its own packet core and NAT, so it is a distinct stratum; a “light” MVNO rides the host’s and is not.

Port preservation

Whether a NAT tries to keep the internal source port as the external one. When it does, a naive guess of “my public IP plus my local port” happens to be correct — which is exactly why the current system sometimes works and learns nothing from it.

QUIC

A modern transport protocol built on UDP with fast connection setup and built-in encryption, used by HTTP/3. Relevant here because QUIC measurement work studies similar NAT-traversal challenges.

RFC 4787 / RFC 5780

RFC 4787 defines NAT behavioural requirements and terminology; RFC 5780 defines the tests that discover that behaviour from the outside, using a server with two addresses and two ports.

Social-graph witness

A peer drawn from your friends or friends-of-friends to help with measurements such as dial-backs. Compared with picking random Internet peers, this is more grassroots-friendly and harder for an

attacker to flood — but it introduces the contamination problem, since friends are exactly the peers you already send to.

Stratified estimation

Measuring each homogeneous group (stratum) of a population separately, then combining the results using published weights for how large each group is. Here it is how a handful of our own devices can still say something about a population — provided the strata really are homogeneous, which is an assumption to be tested rather than assumed.

STUN (RFC 5389)

A protocol by which a peer asks a public server “what does my address look like from your side?”, used to discover its public-facing IP and port. GN has no STUN client; `ADDR_REFLECT` is its nearest equivalent.

TURN (RFC 8656)

A fallback protocol in which a public server relays traffic between two peers when no direct path works. Reliable but expensive, and contrary to GN’s direct-delivery principle.

UDX

The reliable, multiplexed stream protocol over UDP that GN uses for Internet transport, consumed as `grassroots_dart_udx`, a fork of `dart_udx`.